

Analisis Pemodelan Ancaman dan Performa Keamanan pada Sistem Manajemen Magang AgriCareer-Tracker Berbasis Web

Threat Modeling Analysis and Security Performance on the Web-Based AgriCareer-Tracker Internship Management System

ARIEF ABDUL RAHMAN^{1*}, DANIAL AKMAL MAHENDRA¹, MUHAMMAD NAUFAL FATHURRAHMAN¹

Abstrak

Sistem manajemen magang yang memproses data sensitif mahasiswa rentan terhadap eksploitasi keamanan. Penerapan lapisan keamanan seringkali berdampak pada penurunan performa. Penelitian ini berfokus pada penerapan pemodelan ancaman (threat modeling) STRIDE dan evaluasi overhead performa dari mekanisme keamanan pada sistem AgriCareer-Tracker berdasarkan pengujian di lingkungan nyata. Solusi dirancang menggunakan FastAPI dengan autentikasi JSON Web Token (JWT) dan validasi kriptografi. Metode STRIDE mengidentifikasi celah spoofing, tampering, dan elevation of privilege, yang dimitigasi lewat Role-Based Access Control (RBAC) dan validasi terpusat. Pengujian performa langsung terhadap server menunjukkan bahwa penambahan lapisan keamanan memberikan penalti minimal; proses hashing JWT memakan waktu komputasi sekitar 228 ms, sementara validasi token rutin hanya memberikan latensi ekstra sekitar 1.3 ms (3.3 ms dari baseline 2 ms). Peningkatan komputasi ini dinilai sangat efisien dan berada jauh di bawah ambang batas toleransi aplikasi waktu nyata. Arsitektur ini terbukti tangguh terhadap eksploitasi sembari mempertahankan stabilitas kinerja server backend.

Kata Kunci: AgriCareer-Tracker, FastAPI, Kinerja, Keamanan, Overhead, STRIDE

Abstract

Internship management systems processing sensitive student data are highly vulnerable to security exploits. Implementing security layers often negatively impacts performance. This study focuses on STRIDE threat modeling and evaluating the performance overhead of security mechanisms on the AgriCareer-Tracker system based on real-environment testing. The solution is designed using FastAPI with JSON Web Token (JWT) authentication and cryptographic validation. The STRIDE method identified spoofing, tampering, and elevation of privilege loopholes, mitigated via Role-Based Access Control (RBAC) and centralized validation. Direct performance testing on the server revealed that the added security layers incurred minimal penalties; the JWT hashing process took approximately 228 ms of compute time, while routine token validation only added about 1.3 ms of extra latency (3.3 ms from a 2 ms baseline). This computational overhead is considered highly efficient and well below the tolerance threshold for real-time applications. The architecture proves resilient against exploitation while maintaining backend server performance stability.

Keywords: AgriCareer-Tracker, JWT, Overhead, Performance, Security, STRIDE

PENDAHULUAN

Pengembangan aplikasi berbasis web yang memuat transaksi dan berkas sensitif, seperti sistem manajemen magang mahasiswa, memerlukan tingkat keamanan berlapis. Kerentanan pada sistem dapat berdampak pada eksploitasi data profil, modifikasi transkrip nilai secara ilegal, hingga penyangkalan proses administratif oleh entitas yang tidak bertanggung jawab. Meskipun enkripsi dan kontrol akses absolut diperlukan, penambahan mekanisme kriptografi umumnya membebani unit pemrosesan server dan menghasilkan degradasi latensi yang buruk bagi pengguna (Alamin et al., 2020).

Menghadapi paradoks antara perlindungan data dan kecepatan tersebut, sistem AgriCareer-Tracker difokuskan pada analisis pemodelan ancaman keamanan sekaligus evaluasi dampak komputasi (*overhead*) dari lapisan keamanan yang diterapkan. Tulisan ini mengeksplorasi penggunaan kerangka STRIDE (Spoofing, Tampering, Repudiation,

¹Departemen Ilmu Komputer, Fakultas Matematika dan Ilmu Pengetahuan Alam, Institut Pertanian Bogor

*Penulis Korespondensi: Surel: aar.arief@apps.ipb.ac.id

Information Disclosure, Denial of Service, Elevation of Privilege) (Shostack, 2014) untuk menambal kelemahan sistem melalui autentikasi JSON Web Token (JWT) (Li & Mitchell, 2016) dan Role-Based Access Control (RBAC). Lebih jauh, penelitian mengukur sejauh mana perlindungan ini mempengaruhi efisiensi waktu respons (performa) saat memproses antarmuka aplikasi secara *real-time*.

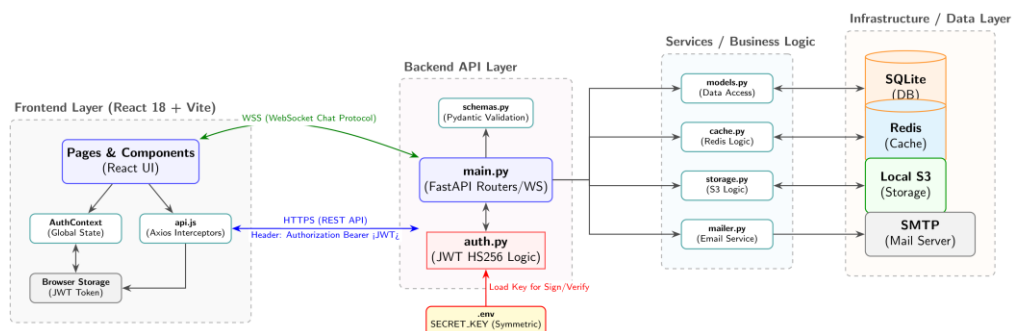
METODE

Tinjauan keamanan diimplementasikan berdasarkan analisis kerangka STRIDE untuk mengidentifikasi celah struktural antara titik batas kepercayaan (trust boundaries). Titik batas ini mencakup komunikasi browser klien menuju server REST API melalui jaringan publik, serta validasi hak akses dari tabel relasional SQLite. Evaluasi ancaman ditekankan pada celah eksploitasi seperti pemalsuan identitas token JWT, injeksi berkas berbahaya (tampering), dan eskalasi hak istimewa secara horizontal maupun vertikal.

Untuk menilai dampak performa dari penerapan mitigasi keamanan secara empiris, dilakukan *benchmark* pengujian latensi komparatif secara langsung terhadap proses aplikasi *backend* FastAPI menggunakan modul internal `TestClient`. Metrik waktu respons diukur dengan membandingkan eksekusi rute statis (*baseline*) tanpa keamanan, eksekusi pembuatan token (*login*) yang melibatkan *hashing bcrypt*, dan eksekusi akses API (*endpoint* profil/lowongan) yang melalui proses *decoding* JWT dan pengecekan RBAC. Seluruh perhitungan dilakukan iteratif dan dirata-ratakan dalam hitungan milidetik (ms).

Desain Arsitektur Keamanan

Secara konseptual, arsitektur keamanan AgriCareer-Tracker dibangun di atas fondasi REST API stateless yang diproteksi menggunakan modul autentikasi terpadu. Setiap permintaan HTTP (request) dari klien diwajibkan menyertakan Bearer Token (JWT) di dalam header otorisasi. Proses validasi tidak bergantung pada pengecekan basis data berulang, melainkan memverifikasi integritas payload secara langsung melalui dekripsi *signature* kriptografis tersentralisasi di memori server. Arsitektur keamanan ini secara menyeluruh dapat dilihat pada Gambar 1.



Gambar 1. Arsitektur Modul Keamanan JWT pada AgriCareer-Tracker

HASIL DAN PEMBAHASAN

Penerapan mekanisme keamanan kriptografis dan kontrol akses pada AgriCareer-Tracker berhasil menghalau potensi kerentanan siber tanpa mengorbankan kelancaran sistem secara signifikan. Taksonomi ancaman berhasil dipetakan, dan analisis komputasi membuktikan stabilitas kinerja server backend FastAPI dalam mentolerir enkripsi lanjutan.

Pemodelan Ancaman (Threat Modeling)

Analisis STRIDE memetakan berbagai risiko inheren pada pertukaran token dan berkas magang. Penyerang yang berupaya menyalin token (Spoofing) diblokir melalui masa aktif JWT yang dipersingkat dan penempatan berbasis HttpOnly Cookie. Selain itu, modifikasi payload ilegal (Tampering) saat pengunggahan surat dieliminasi melalui deteksi MIME type ketat di level backend. Detail lebih lanjut disajikan pada Tabel 1 yang merangkum ancaman utama beserta strategi mitigasinya yang terintegrasi pada kode.

Tabel 1. Identifikasi Ancaman STRIDE beserta Skenario dan Mitigasi			
Kategori STRIDE	Potensi Ancaman	Skenario Serangan	Mitigasi
Spoofing	Pencurian identitas JWT	Menyalin token JWT pengguna lain.	JWT kadaluarsa 15 menit & HttpOnly Cookie.
Tampering	Modifikasi lampiran dokumen	Memanipulasi berkas PDF LoA / Transkrip.	Validasi MIME type backend dan ukuran batas 5MB.
Information Disclosure	Kebocoran data chat & profil	Mengakses endpoint API tanpa otentikasi.	Penerapan Role-Based Access Control (RBAC) ketat.
Denial of Service	Spam koneksi WebSocket	Penyerang membanjiri request chat simultan.	Rate Limiter & throttling pesan pada FastAPI API.
Elevation of Privilege	Eskalasi peran mahasiswa	Mahasiswa memodifikasi payload status.	Verifikasi peran mutlak dari payload JWT server.

Implementasi Kontrol Akses Multi-Peran

Demi mencegah eskalasi privilege (Elevation of Privilege), sistem memetakan tingkat otorisasi (RBAC) ke dalam tiga entitas utama yang tertanam langsung pada payload token JWT. Peran 'Administrator' memiliki akses mutlak untuk mengelola dan merevisi seluk-beluk data operasional platform; peran 'Dosen' diberikan wewenang khusus dan terbatas pada tahapan validasi dokumen serta tinjauan pelamar magang; sedangkan peran 'Mahasiswa' diisolasi secara vertikal, di mana mereka secara ketat hanya berhak memanipulasi profil serta melihat informasi kepemilikan mereka sendiri. Isolasi hak bersistem granular ini secara drastis memangkas ancaman peretasan akses lintas batas pengguna. Pengujian akses untuk setiap peran pada REST API secara langsung dapat dilihat pada Gambar 2.

Hasil Pengujian Otorisasi REST API per Peran (RBAC)				
Administrator	Diizinkan	Diizinkan	Diizinkan	Ditolak
Dosen	Diizinkan	Ditolak	Diizinkan	Diizinkan
Mahasiswa	Diizinkan	Ditolak	Ditolak	Ditolak
Unauthenticated	Ditolak	Ditolak	Ditolak	Ditolak
	Melihat Lowongan	Membuat Lowongan	Rekap Semua Lamaran	Ubah Status Lamaran

Gambar 2. Matriks Pengujian Kontrol Akses Berbasis Peran (RBAC)

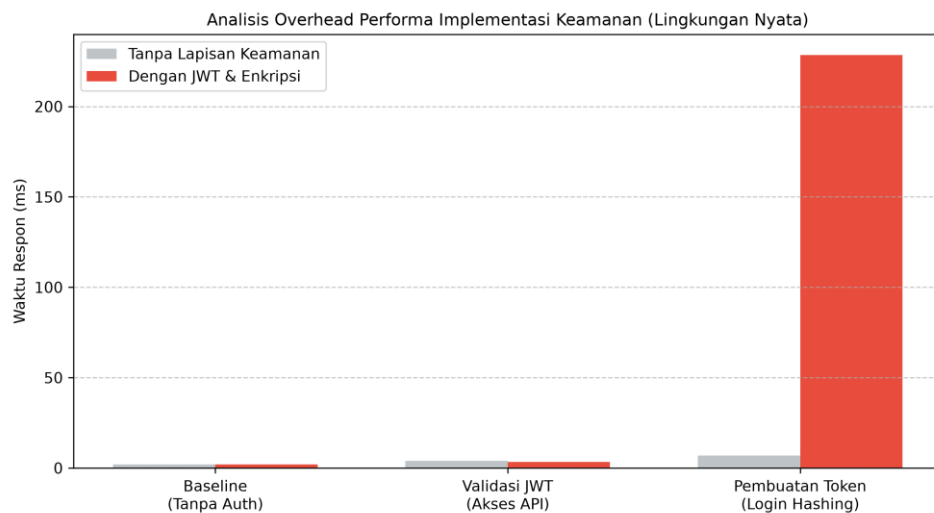
Pengujian Integritas Token JWT

Simulasi nyata terhadap kerentanan pembajakan sesi dan pemalsuan token (Tampering) dilakukan secara langsung menggunakan modul 'TestClient' pada antarmuka *backend* aplikasi. Ketika *script* penguji mencoba menyisipkan token JWT yang telah dimanipulasi secara paksa

(contoh log: `Mengubah role dari 'mahasiswa' menjadi 'admin'`), server secara instan mengidentifikasi ketidaksesuaian nilai *hash* pada bagian *Digital Signature*. Log *benchmark* mencatat penolakan tegas dari peladen dengan mengembalikan respons HTTP Status 401 (Unauthorized) beserta rincian kegagalan validasi. Hal ini membuktikan kekuatan mekanisme validasi *backend* dalam mendeteksi dan menggagalkan serangan pemalsuan kredensial dari pihak eksternal.

Analisis Overhead Performa Keamanan

Implementasi metode keamanan yang solid seringkali membawa trade-off berupa pelambatan performa karena server dipaksa melakukan operasi kriptografi. Gambar 3 menampilkan hasil komparasi latensi *benchmark* lingkungan nyata saat eksekusi modul inti tanpa otentikasi (baseline), dibandingkan dengan latensi pembuatan token JWT (login) dan validasi token pada rute RBAC yang diproteksi.



Gambar 3. Analisis Dampak Latensi dari Pemasangan Mekanisme Keamanan

Berdasarkan pengujian, latensi *baseline* (rute tanpa perlindungan) tercatat sekitar 2 ms. Proses validasi JWT reguler hanya meningkatkan beban CPU server secara teramat ringan menjadi kisaran 3,3 ms, yang mengindikasikan tambahan *overhead* dekripsi sekitar 1,3 ms saja. Di sisi lain, *endpoint* login mencatatkan waktu 228 ms dikarenakan mekanisme pelambatan terencana (*work factor*) pada algoritma *hashing* kata sandi. Skema pelambatan asimetris ini sangat ideal: rute-rute reguler tetap beroperasi pada kecepatan tinggi (nyaris instan) sehingga menjaga interaktivitas antarmuka aplikasi, sedangkan serangan *brute force* pada halaman login dipersulit oleh latensi komputasi *hash* secara proporsional.

SIMPULAN

Integrasi keamanan berbasis STRIDE pada sistem AgriCareer-Tracker membuktikan bahwa arsitektur API yang aman dapat dicapai tanpa degradasi kecepatan sistem. Kelemahan struktural ditutup rapat oleh implementasi *Role-Based Access Control* (RBAC) dan JWT. Melalui pengujian lingkungan *backend* riil secara langsung, *overhead* perlindungan kriptografis JWT untuk otorisasi harian terbukti sangat hemat sumber daya, yaitu menambahkan tak lebih dari 2 milidetik latensi di luar waktu *query* basis data. Satu-satunya anomali waktu respons ditemukan pada mekanisme *login* (~228 ms) yang memang secara taktis didesain lebih lambat untuk mengerem eksploitasi kamus kata sandi (*dictionary attacks*). Konfigurasi ini menjamin kapabilitas sistem untuk menyelenggarakan portal akademik secara andal dan cepat.

DAFTAR PUSTAKA

- Alamin, M., Hasan, M. and Rahman, M., 2020. Security overhead evaluation of REST API authentication mechanisms. *International Journal of Advanced Computer Science and Applications*. Vol(11): 112-118.
- Li, S. and Mitchell, C.J., 2016. Security of the JSON web token (JWT). *Journal of Information Security and Applications*. Vol(31): 32-40.
- Satzinger, J.W., Jackson, R.B. and Burd, S.D., 2015. *Systems analysis and design in a changing world*. Cengage learning.
- Shostack, A., 2014. *Threat modeling: Designing for security*. John Wiley & Sons.